

[TMS+23,Arxiv] Robust, Privacy-preserving, Transparent, and Auditable on-device blocklisting

SUMMARY: This paper proposed a system for client-side scanning with better transparency and auditability.

1 Motivation

Client-side scanning is a hot topic in legislation, with many regulators attempting to force applications to deploy the mechanism. However, preventing the abuse of this mechanism is an open problem. For example, the server may detect legal contents on the clients.

2 Participants & Goals

Participants. The system involves: 1) Curators maintain the blocklists; 2) Enforcers execute the PSI with the clients; 3) Clients query the enforcers for CSAM detection. 4) Auditor audits the PSI results and blocklists consistency.

Goals

- **Transparency.** The server must provide the curator's signature of the block entries to the client, which proves the validity of the entries.
- **Consistency.** 1) All clients see the same blocklist. 2) The update o blocklist is recorded.
- **Auditability.** An auditor can reconstruct the history of the blocklist entries.

Notable Settings

- **Client-side output.** Unlike Apple PSI, the PSI protocol in the system outputs the result to the clients. The authors claim this provides better privacy for clients.
- **No perceptual hash.** The system does not use perceptual hash since it brings false positives and is vulnerable to attacks.
- **No probabilistic data structure or hash prefix.** 1) Hash prefix would leaks partial information about an object. 2) PDS creates a side-channel that leaks the knowledge of client/server's set.

3 Methodology

Transparency is achieved by the curators' signature on the blocklist entries.

Consistency is achieved by a merkle tree whose leaves are the hash of all elements in blocklist. Whenever the curators update the blocklists, a new leaf is inserted into the tree.

Auditability.

- Privileged auditor has access to all the blocklist entries, thus it can rebuild the entire merkle tree.
- Unprivileged auditor redo the behavior of users, which guarantees the enforcers' misbehavior can be audit by somebody.

Detection is achieved by the PSI protocol.

- Time-efficient PSI use DH-KE based PSI with pre-processing.
- Space-efficient PSI use FHE-based PSI.

A notable setting is client-side output, which allows 1) the online phase to be time-efficient; otherwise, the client would have $O(N)$ computational overhead. 2) the users can verify the crators' signature after a match occurs, which is impossible in server-side output.

4 Evaluation

	Time-efficient			Parameter	Space-efficient		
	<i>Pixel 2XL</i>	<i>Pixel 6 Pro</i>	<i>Bandwidth</i>		<i>Pixel 2XL</i>	<i>Pixel 6 Pro</i>	<i>Bandwidth</i>
Query	425 μ s	100 μ s	32 bytes	$N = 4096$	7.99 ms	2.99 ms	92.9 KB
				$N = 8192$	20.4 ms	6.85 ms	432.7 KB
Verification	257 μ s	69 μ s	32 bytes	$N = 4096$	8.35 ms	2.57 ms	10.2 KB
				$N = 8192$	36.7 ms	10.2 ms	20.5 KB

TABLE III: Client-side computation and bandwidth costs to determine the blocklist status of a single object.

5 Observation & Insight